YMMV Industrial

Event Observability Standard

Document ID: YMMV-SEC-STD-014 **Classification:** Public - Example **Version:** 1.0 **Effective date:** 2026-10-10 **Review cycle:** Annual
Document owner: Cybersecurity Governance, Risk, and Compliance **Approved by:** Avery Chen, Chief Information Security Officer
Approval status: Approved for educational evaluation

> **EXAMPLE DOCUMENT - NOT AN OPERATING COMPANY STANDARD**
> YMMV Industrial is a fictitious organization. Names, systems, roles, and policy choices in this document are illustrative. This document is supplied as a realistic test artifact for EventMill and must not be adopted without legal, regulatory, privacy, operational, and technical review.

Document control

Field	Value
Business sponsor	Office of the Chief Information Security Officer
Policy custodian	Director, Cybersecurity Governance, Risk, and Compliance
Technical authority	Director, Security Engineering and Operations
Applies to	YMMV Industrial information systems, applications, services, and managed technology
Supersedes	New document
Next scheduled review	2027-10-10
Authoritative copy	YMMV policy repository (fictional)

Revision history

Version	Date	Author or owner	Description	Approval
0.1	2026-08-15	Cybersecurity GRC	Initial draft	Draft
0.8	2026-09-18	Security Architecture Council	Technical and privacy review	Reviewed
1.0	2026-10-10	CISO	First educational release	Approved

Approval record

Approval signifies that the approver has reviewed the purpose, scope, risk position, and assigned responsibilities. Approval does not certify any product, system, or service as compliant.

Name	Title	Decision	Date
Avery Chen	Chief Information Security Officer	Approved	2026-10-10
Rowan Patel	Chief Technology Officer	Concurred	2026-10-08
Morgan Reyes	General Counsel and Privacy Officer	Concurred with disclaimer	2026-10-08

1. Purpose, authority, and objectives

1.1 Purpose

This standard establishes minimum requirements for generating, formatting, transmitting, protecting, retaining, reviewing, and disposing of observability event records at YMMV Industrial. It is intended to ensure that authorized personnel can reconstruct significant activity, investigate cybersecurity and operational events, detect abnormal behavior, and demonstrate that defined logging controls operate as intended.

The standard translates recognized public guidance into a fictional enterprise control environment. Its principal sources are NIST SP 800-53 Revision 5 Audit and Accountability controls, NIST SP 800-171 Revision 3 section 3.3, NIST SP 800-92, ISO 8601-1:2019, CIS Controls v8 Control 8, and platform-specific CIS Benchmark guidance. Source identifiers appear in brackets and are fully listed in Appendix C.

1.2 Authority

The Chief Information Security Officer issues this standard under the fictional YMMV Information Security Policy. System owners remain accountable for their systems. Service owners and custodians may delegate implementation tasks but may not delegate accountability for satisfying approved requirements.

1.3 Objectives

YMMV Industrial shall maintain observability records that, in proportion to risk and technical capability:

1. identify the kind of event that occurred;
2. establish when and where it occurred;
3. identify its source, outcome, and associated people, processes, objects, or other entities;
4. support investigation, correlation, alerting, and after-the-fact review;
5. remain available and protected for their approved retention period; and
6. avoid unnecessary collection or exposure of sensitive information.

Objectives 1 through 3 reflect the audit-record-content concepts in NIST SP 800-53 AU-3 and NIST SP 800-171r3 03.03.02. Objectives 4 through 6 address the wider log-management lifecycle described by NIST and CIS. [SRC-NIST-53; SRC-NIST-171; SRC-NIST-92; SRC-CIS-8]

1.4 Normative language

The words **shall** and **must** state mandatory YMMV requirements. **Should** states a recommended practice for which a documented reason is expected when not followed. **May** indicates an option. **Where technically feasible** does not create an automatic exception; the system owner must record the constraint, risk, compensating control, and remediation decision.

1.5 Relationship to other requirements

Where law, contract, regulation, safety obligations, or a system-specific standard imposes a stronger requirement, the stronger requirement applies. If requirements conflict, the system owner shall stop the affected implementation decision and obtain direction from Cybersecurity GRC, Legal and Privacy, and the appropriate records-management authority.

2. Scope and applicability

2.1 In-scope technology

This standard applies to production and production-supporting information systems operated by or for YMMV Industrial, including:

- business applications, application programming interfaces, and integration services;
- identity, authentication, authorization, and privileged-access services;
- servers, workstations, network devices, operational technology gateways, and security appliances;
- cloud services, managed services, containers, orchestration platforms, and serverless workloads;
- databases, data platforms, message brokers, and storage services;
- development, test, and recovery environments when they contain production data, security-sensitive functions, or privileged administrative access; and
- third-party services where YMMV has contractual authority to require or obtain relevant event records.

Safety instrumented systems and regulated operational technology may require a separate hazard analysis before logging settings are changed. This standard does not authorize changes that could impair a safety function.

2.2 In-scope records

“Observability event record” is the umbrella term used in this document for a machine-generated record describing an occurrence within an information asset. It includes security audit records, application events, infrastructure logs, access records, administrative activity, selected metrics with event meaning, and trace events. Metrics representing only an aggregate measurement are not automatically audit records, but shall be governed when used as evidence of a security-relevant or operational event.

2.3 Out of scope

This document does not prescribe a particular logging product, index, query language, message transport, regular expression, or vendor schema. It does not require collection of payload contents merely because they are available. It does not replace records schedules, privacy assessments, incident-response plans, safety standards, or contractual notification duties.

2.4 Applicability tiers

System owners shall assign one of the following tiers during design and review:

Tier	Typical characteristics	Minimum expectation
O1 - Essential	Internal, low sensitivity, limited security impact	Core event generation, time, protection, and review controls
O2 - Important	Sensitive data, business-critical service, external access	O1 plus detailed identity, outcome, centralized collection, and monitoring
O3 - Critical	Safety, privileged control, regulated data, material business impact	O2 plus enhanced correlation, rapid failure notification, stronger integrity and availability controls

Tiering is a YMMV risk decision, not a NIST or CIS classification. A lower tier does not waive an externally imposed obligation.

2.5 Shared-responsibility services

For cloud and managed services, the service owner shall document which party generates, stores, protects, reviews, and disposes of each required event source. Unavailable provider logs shall be recorded as a control limitation, not assumed to exist. Contracts should preserve timely authorized access to relevant service provider logs, consistent with CIS Safeguard 8.12. [SRC-CIS-8]

3. Governance, accountability, and lifecycle

3.1 Governance principles

Logging shall be purposeful, risk-informed, proportionate, and reviewable. Collection shall be based on documented security, operational, safety, legal, or business needs. More data is not automatically better evidence. Unnecessary collection can increase cost, obscure significant activity, and expose personal or confidential information.

3.2 Roles and responsibilities

Role	Responsibilities
CISO	Approves this standard and accepts enterprise-level residual risk
Cybersecurity GRC	Maintains the standard, maps external sources, tracks exceptions, and coordinates assessments
Security Engineering and Operations	Operates central collection and analysis capabilities; defines approved technical patterns
System owner	Selects events, approves applicability, funds implementation, and owns remediation
Service or application owner	Implements record generation, validates fields, and documents event semantics
Platform custodian	Configures platform audit facilities, forwarding, storage, health monitoring, and time services
SOC and incident response	Reviews alerts and records, reports findings, and preserves investigation evidence
Privacy and Legal	Reviews sensitive-data collection, legal holds, disclosure, and jurisdictional constraints
Records management	Approves retention and defensible disposal schedules
Internal audit or assurance	Performs independent testing and reports control deficiencies
Users and administrators	Do not disable, bypass, alter, or delete observability controls except through approved procedures

3.3 Event-source inventory

Each O2 and O3 system shall maintain an inventory of material event sources. The inventory shall identify the owner, producing component, purpose, selected event categories, destination, approximate volume, sensitivity, retention class, time source, and review mechanism. The inventory shall be reviewed annually and after significant architectural or threat changes. This implements the planning intent of NIST SP 800-92 and CIS Safeguard 8.1. [SRC-NIST-92; SRC-CIS-8]

3.4 Lifecycle requirements

Observability controls shall be considered during requirements definition, design, acquisition, development, testing, release, operation, major change, incident response, and decommissioning. Changes to authentication, authorization, administrative functions, external interfaces, or sensitive data flows shall trigger review of event selection and record content.

3.5 Documentation

System documentation shall describe event identifiers and meanings, field semantics, custom status or outcome codes, time conventions, expected volume, known gaps, and operational ownership. Custom event codes shall have a stable definition accessible to authorized analysts. Documentation may refer to a vendor specification or schema registry rather than duplicate it.

3.6 Training and awareness

Personnel who design or operate logging shall receive role-appropriate training on event selection, sensitive-data handling, time synchronization, failure response, and investigation use. Administrators shall understand that disabling or modifying auditing outside an authorized change can constitute a security incident and a policy violation.

4. Risk assessment, event selection, and exceptions

4.1 Event selection

System owners shall specify the event types selected for logging and review the selection at an organization-defined frequency. The selection shall support investigation and accountability without imposing unjustified operational or privacy risk. This requirement is derived from NIST SP 800-53 AU-2 and NIST SP 800-171r3 03.03.01. [SRC-NIST-53; SRC-NIST-171]

At a minimum, the selection analysis shall consider:

- authentication and session establishment, including failures;
- authorization decisions and access denials;
- creation, change, disabling, or deletion of accounts and privileges;
- use of privileged or administrative functions;
- changes to security-relevant configuration;
- access to, modification of, or deletion of sensitive information where appropriate and lawful;
- application, service, job, and integration start, stop, failure, and recovery;
- audit or logging service start, stop, configuration change, storage pressure, forwarding failure, and processing failure;
- security-control detections and responses; and
- material transactions identified by the system owner's risk assessment.

These categories are YMMV's general selection baseline. System-specific details remain organization-defined, as contemplated by AU-2.

4.2 Platform configuration baselines

Platform custodians shall enable the approved native audit facility and ensure that it starts and remains active as required by the platform baseline. CIS Benchmarks commonly express this as a configuration check rather than a record content requirement. For example, the public CIS Oracle Linux 6 Benchmark v1.0.0 section 4.1.2 requires the `auditd` service to be enabled to record system events. Current supported platforms shall use the current YMMV-approved CIS Benchmark version applicable to that platform. [SRC-CIS-OL6; SRC-CIS-BENCH]

4.3 Risk and privacy analysis

Before enabling unusually detailed logging, the owner shall consider system performance, storage, network load, confidentiality, employee monitoring, secrets exposure, legal privilege, data residency, and safety. Sensitive fields shall be minimized, masked, tokenized, or excluded when their investigative value does not justify collection risk.

4.4 Exceptions

An exception request shall identify:

1. the specific requirement and affected assets;
2. the technical or business reason;
3. the risk and affected evidence or detection capability;
4. compensating controls;
5. a remediation plan and target date;
6. an accountable owner; and
7. approval by the designated risk authority.

Exceptions shall be time-limited and reviewed at least annually. An absent event type, unavailable provider log, or unparseable proprietary format is a visible limitation requiring disposition; it shall not be silently treated as compliant.

4.5 Emergency changes

Emergency actions may temporarily alter logging when necessary to protect life, safety, availability, or containment objectives. The action, authorization, duration, impact on evidence, and restoration shall be recorded and reviewed as soon as practicable.

5. Event record content requirements

5.1 Core content

Each observability event record shall contain, directly or through an unambiguous association with its source stream, enough information to determine:

1. **what** type of event occurred;
2. **when** the event occurred;
3. **where** the event occurred;
4. the **source** of the event;
5. the **outcome** of the event, when an outcome exists; and
6. the identity of relevant **individuals, subjects, objects, processes, or other entities** associated with the event.

These elements restate NIST SP 800-53 AU-3 and NIST SP 800-171r3 03.03.02 in generic language. The standards allow additional information where needed. [SRC-NIST-53; SRC-NIST-171]

5.2 Event type

The event type shall be represented by a stable name, identifier, or documented code. A custom numeric or textual code is acceptable when its meaning is documented and distinguishable from unrelated values. Event types shall remain consistent enough to support searching, counting, correlation, and trend analysis across supported versions.

5.3 Date and time

Every event record shall include both the date and time at which the event occurred. Date and time may appear anywhere in the physical record and may be split across fields, provided the fields can be reliably associated. The value shall be machine parseable and internally valid rather than merely matching a textual pattern.

Observability timestamps should conform to ISO 8601-1:2019 when technically feasible. They shall use UTC, a fixed local offset from UTC, or include the local offset. Ambiguous local time without an offset shall be documented and remediated according to risk. ISO identifies representations for calendar dates, 24-hour time, UTC, and offsets; NIST AU-8 requires audit timestamps with organization-defined granularity and a UTC relationship. [SRC-ISO-8601; SRC-NIST-53; SRC-NIST-171]

5.4 Location and source

Location and source shall identify the relevant execution context with enough specificity for investigation. Depending on architecture, this may be a host, service, application, tenant, cloud account, region, container, function, device, facility, network address, component, or other stable identifier. Values inherited from a trusted stream envelope are acceptable when the association survives transport and storage.

5.5 Identity and affected entities

Where applicable, records shall identify the initiating user, service account, process, workload, device, or other subject and the object or resource affected. Group or shared identities should be supplemented with the individual or workload identity when supported. Identifiers shall be stable enough for authorized correlation and shall not expose credentials or authentication secrets.

5.6 Outcome and event details

When an operation has an outcome, the record shall distinguish success, failure, denial, partial completion, cancellation, timeout, or another documented state. Additional detail may include source and destination addresses, process identifiers, object names, invoked access-control rules, or event-specific results where needed for the auditing function. [SRC-NIST-171]

6. Record quality, structure, and correlation

6.1 Consistency

Within a defined event type and supported software version, field meanings and encodings shall be consistent. A field shall not alternate between materially different meanings without a version or discriminator. Optional and inapplicable fields shall be distinguishable from extraction failure or malformed content.

6.2 Parseability

Records shall be capable of deterministic parsing using documented structure, delimiters, field labels, a published schema, or other stable rules. YMMV does not require a specific serialization format. Structured JSON, delimited text, key-value records, and documented free-text formats may all satisfy this requirement.

Free-form messages shall not be the sole representation of a mandatory element when the message wording changes unpredictably. Multiline records shall provide a reliable boundary or continuation rule. Escaping and character encoding shall be documented where ambiguity could corrupt field boundaries.

6.3 Completeness and validity

Required elements shall be populated for applicable records. Values shall be syntactically valid for their declared type and reasonable for their semantic role. Examples include calendar-valid timestamps, valid network addresses, documented event codes, and identifiers that conform to the producing system's rules.

A value that merely resembles a date, status, or identity does not by itself establish its meaning. Field semantics shall be supported by documentation, labels, stable position, consistent values, or other corroborating evidence.

6.4 Time quality and synchronization

Systems shall use approved internal clocks to generate event timestamps and synchronize them to authoritative time sources appropriate to the environment. YMMV O2 and O3 systems shall use at least two synchronized time sources where supported, aligning with CIS Safeguard 8.4. Clock-source configuration, synchronization status, drift tolerance, and failure response shall be documented. [SRC-NIST-53; SRC-NIST-171; SRC-CIS-8]

The required timestamp granularity shall reflect the event rate and investigative need. Systems producing multiple relevant events within the same timestamp unit should provide finer granularity or an ordering mechanism.

6.5 Correlation

Distributed or transactional systems should record a correlation, request, trace, transaction, or session identifier when needed to connect related events. Identifiers shall not be reused in a manner likely to merge unrelated activity within the retention period. Correlation across repositories supports the organization-wide awareness described by NIST AU-6 and NIST SP 800-171r3 03.03.05. [SRC-NIST-53; SRC-NIST-171]

6.6 Schema and version management

Material changes to record boundaries, field names, types, meanings, or custom codes shall be versioned and communicated before deployment when feasible. Producers and consumers shall be tested together. Deprecated formats shall have a documented transition period appropriate to operational risk.

6.7 Prohibited content

Passwords, private keys, session secrets, access tokens, full authentication answers, and equivalent credentials shall not be recorded. Other sensitive content shall be limited to the minimum necessary and protected according to its classification.

7. Collection, transport, capacity, and failure handling

7.1 Collection

Logging shall be enabled across in-scope enterprise assets according to the approved event-source inventory. This reflects CIS Safeguard 8.2 and NIST AU-12. The generating system shall produce audit records for selected events using the approved record content. [SRC-CIS-8; SRC-NIST-53]

7.2 Centralization

O2 and O3 systems shall forward security-relevant records to an approved central collection or analysis service to the extent possible. Local records may be retained for resilience or troubleshooting, but local storage alone shall not be the normal control for systems exposed to compromise. This aligns with CIS Safeguard 8.9 and the centralized log-management practices in NIST SP 800-92. [SRC-CIS-8; SRC-NIST-92]

7.3 Transport

Transport shall preserve record content, source attribution, timestamps, and ordering information to the extent supported. Records transmitted over untrusted or shared networks shall receive confidentiality and integrity protection commensurate with their classification and risk. Failed delivery shall be detectable, retried or queued where feasible, and subject to bounded back-pressure controls.

7.4 Storage capacity

Logging destinations shall maintain capacity consistent with expected volume, surge conditions, and the approved retention period. Capacity shall be monitored before exhaustion. This implements NIST AU-4 and CIS Safeguard 8.3. Capacity planning assumptions shall be reviewed after material changes in event volume, format, retention, or system population. [SRC-NIST-53; SRC-CIS-8]

7.5 Response to processing failures

Systems shall alert designated personnel or roles when audit logging or processing fails, in accordance with the system's criticality and response plan. Failure conditions include inability to generate, buffer, transmit, ingest, index, store, or retrieve required records and exhaustion of storage. Additional actions shall be selected by risk, including failover, traffic restriction, controlled shutdown, overwriting rules, or manual intervention. This requirement is derived from NIST AU-5 and NIST SP 800-171r3 03.03.04. [SRC-NIST-53; SRC-NIST-171]

7.6 Health evidence

The monitoring service shall retain evidence sufficient to determine material collection gaps, delayed ingestion, parser failures, rejected records, and source silence. A healthy collector does not prove that every source generated all required events; source and pipeline health shall be evaluated separately.

7.7 Resilience and recovery

O3 logging designs shall document behavior during network partitions, destination outages, local resource pressure, and recovery. Queues and local buffers shall be sized and protected according to risk. Recovery procedures shall address duplicate delivery and gaps without silently rewriting original event meaning.

8. Protection, access control, and privacy

8.1 Protection of audit information

Observability records and logging tools shall be protected from unauthorized access, modification, and deletion. Access to management of audit functionality shall be limited to an authorized subset of privileged users or roles. These requirements are based on NIST AU-9 and NIST SP 800-171r3 03.03.08. [SRC-NIST-53; SRC-NIST-171]

8.2 Least privilege and separation of duties

Access shall be granted according to job responsibilities and least privilege. Where practical, personnel who administer a monitored production service shall not be able to alter or delete the authoritative copy of its security audit records. Elevated access to logging systems shall itself be logged and reviewed.

8.3 Access authorization

Access roles shall distinguish at least administration, ingestion, search, investigation, reporting, and read-only assurance functions where the platform supports them. Authorization shall be approved by the data or system owner and reviewed periodically. Dormant and unnecessary access shall be removed.

8.4 Confidentiality and data handling

Records shall be classified and handled according to the most sensitive content they contain. Encryption at rest and in transit shall be applied according to YMMV cryptographic and data-protection standards. Exported records, reports, and support bundles remain subject to the same handling restrictions.

8.5 Integrity and provenance

Authoritative stores shall preserve provenance sufficient to associate records with their source and collection path. O2 and O3 services shall use platform controls that detect or prevent unauthorized alteration and deletion. Where records are transformed, the organization shall preserve the original content or a verifiable authoritative copy as required for investigations and audit record reduction. NIST AU-7 emphasizes preserving original content and time ordering during reduction and reporting. [SRC-NIST-53; SRC-NIST-171]

8.6 Privacy and data minimization

Event design shall minimize personal, confidential, and regulated data while preserving the defined security and operational purpose. Collection of message bodies, query text, file content, or precise user behavior requires documented necessity and Privacy or Legal review when applicable.

Search and export activity involving sensitive records shall be logged. Investigative access shall be limited to a legitimate purpose, and downstream copies shall have an owner and disposition method.

8.7 Non-production use

Production records shall not be copied into development or test environments unless authorized protections are equivalent and the use is approved. Synthetic or de-identified events should be used for parser, analytics, and training tests when they meet the purpose.

8.8 Legal hold

An authorized legal hold or investigation preservation notice suspends normal disposal for the identified records. Holds shall be scoped, documented, protected, and released only by the authorized function.

9. Retention, archival, and disposal

9.1 Retention policy

Audit records shall be retained for an organization-defined period consistent with legal, regulatory, contractual, operational, and risk requirements, as required by NIST AU-11. CIS Safeguard 8.10 specifies a minimum of 90 days across enterprise assets for its implementation groups. [SRC-NIST-53; SRC-CIS-8]

For this fictional example, YMMV selects the following internal schedule:

Record class	Online searchable	Total retention	Notes
O1 general observability	30 days	90 days	Unless another schedule applies
O2 security and access records	90 days	365 days	Supports investigation and seasonal review
O3 critical or regulated records	180 days	730 days	Subject to system-specific schedule
Incident evidence	Case-defined	Case-defined	Governed by incident and legal requirements

These periods are YMMV policy choices for the example; NIST AU-11 deliberately leaves the period to the organization. They are not universal legal advice.

9.2 Retention metadata

The event-source inventory shall identify the applicable retention class, authoritative repository, archive mechanism, and disposal owner. Retention shall be measured from the event date unless an approved records schedule specifies a different trigger.

9.3 Archival and retrieval

Archived records shall remain readable, protected, and retrievable within a documented service objective. The organization shall preserve the schema, parser, keys, and contextual information needed to interpret archived records. Periodic recovery tests shall confirm that selected records can be located, restored, and understood.

9.4 Disposal

Records shall be disposed of after the approved retention period unless subject to legal hold, investigation preservation, or another authorized suspension. Disposal shall use approved media-sanitization and cloud-deletion processes appropriate to the storage service and data classification. Disposal evidence shall be retained according to the records-management program.

9.5 Retention verification

Owners shall periodically verify repository configuration, oldest and newest available records, retrieval, and disposal behavior. A sample file’s earliest timestamp can demonstrate only the time range present in that file; it cannot by itself prove enterprise retention configuration, archival protection, continuous collection, or defensible disposal.

9.6 Capacity and retention changes

Retention shall not be shortened solely to resolve an unplanned capacity shortfall without documented risk authorization. Material changes to record volume, field size, compression, indexing, or replica count shall trigger capacity review.

10. Review, analysis, reporting, and response

10.1 Review and analysis

Authorized personnel shall review and analyze audit records at a defined frequency for indications and potential impact of inappropriate or unusual activity, and report findings to designated roles. Records from different repositories shall be correlated where needed for organization-wide situational awareness. This reflects NIST AU-6 and NIST SP 800-171r3 03.03.05. [SRC-NIST-53; SRC-NIST-171]

10.2 Review frequency

For this fictional standard, YMMV selects:

- continuous automated monitoring for defined O3 security conditions;
- daily review of critical collection failures and high-severity alerts;
- weekly review of material anomalies for O2 systems; and
- monthly review of source health, parsing failures, and coverage trends.

CIS Safeguard 8.11 calls for audit-log reviews weekly or more frequently. The additional frequencies above are YMMV choices based on fictional risk tiers. [SRC-CIS-8]

10.3 Reduction, search, and reporting

Logging services shall support reduction and report generation needed for review, analysis, reporting, and after-the-fact investigation while preserving original content and time ordering. Search should support relevant date/time, identity, source, event type, object, address, and outcome fields when present. This requirement is based on NIST AU-7. [SRC-NIST-53]

10.4 Detection and alerting

Alert logic shall identify its data sources, required fields, expected event types, thresholds or conditions, owner, severity, and response path. An alert shall not be described as effective solely because the required fields exist. Evidence shall separately address collection health, parsing, rule execution, alert delivery, and analyst response.

10.5 Incident response

Records relevant to an incident shall be preserved with provenance and access restrictions appropriate to the investigation. Analysts shall record query scope, time range, source systems, transformations, known gaps, and export details. Copies used as evidence shall be protected against unauthorized change.

10.6 Quality monitoring

Owners shall monitor trends in malformed records, missing mandatory elements, unknown event codes, parser failures, ingestion delay, duplicate events, source silence, and timestamp drift. Material regressions shall be treated as defects and remediated through normal risk and change-management processes.

10.7 Service provider records

Service owners shall obtain relevant provider logs where supported, including authentication, authorization, administrative, data-lifecycle, and security events appropriate to the service. Provider limitations, delivery delays, and retention constraints shall be documented. [SRC-CIS-8]

11. Compliance, assurance, and enforcement

11.1 Evidence-based assessment

Compliance shall be assessed using evidence appropriate to each requirement. Possible evidence includes configuration exports, service health records, access reviews, records schedules, architecture diagrams, tickets, contracts, and sampled event records. No single artifact is expected to prove the whole standard.

11.2 Requirements testable from event content

Automated inspection of representative records can provide evidence about:

- presence and population of required content elements;
- syntactic validity of timestamps, identifiers, addresses, and codes;
- consistency of record boundaries and field positions;
- stability of event type and outcome mappings;
- prevalence of malformed or unmatched records;
- explicit timezone or UTC-offset representation;
- apparent schema or format versions; and
- record types observed in the supplied dataset.

Content inspection may support, but does not conclusively prove, semantic meaning. For example, a valid timestamp-shaped field must still be shown to represent when the event occurred rather than an unrelated expiry time.

11.3 Requirements not testable from record content alone

Reviewing record text alone cannot establish:

- whether all required event categories were enabled;
- whether absent events never occurred or failed to be recorded;
- clock synchronization configuration or actual clock accuracy;
- continuous forwarding, loss during transport, or source silence;
- repository capacity and failure-response configuration;
- access authorization, separation of duties, or administrative review;
- encryption, tamper resistance, or protection against deletion;
- approved retention, archival, legal hold, or defensible disposal;
- review frequency, alert delivery, analyst response, or staff training; or
- exception approval, governance, contractual rights, and management oversight.

These requirements need configuration, process, or corroborating evidence.

11.4 Assessment outcomes

Assessors shall use outcomes that preserve uncertainty:

Outcome	Meaning
Supported	Available evidence supports the applicable requirement
Partially supported	Some elements or record types meet it; material gaps remain
Not supported	Evidence demonstrates an applicable requirement is not met
Not observed	The relevant event or condition did not appear in the reviewed dataset
Not testable from log	Record content cannot establish the requirement
Not applicable	Approved scope or event semantics make the requirement inapplicable
Indeterminate	Evidence is insufficient or semantic mapping remains unresolved

11.5 Consequences of non-compliance

Non-compliance shall be documented, risk-ranked, assigned to an accountable owner, and tracked to remediation or approved risk disposition. YMMV may require corrective action plans, restrict deployment, reduce system connectivity, suspend a change, increase monitoring, or escalate residual risk to executive leadership. Deliberate unauthorized disabling, alteration, concealment, or deletion of audit controls or records may result in access suspension, disciplinary action up to termination, contractual remedies, and referral to legal or regulatory authorities, subject to applicable law and agreement.

11.6 No implied certification

A successful parser, high field-population rate, or favorable automated report does not certify a system, implementation, organization, or product as compliant with NIST, CIS, ISO, or this example standard.

Appendix A. Minimum content assessment profile

This appendix summarizes the core record-content profile for automated testing. It does not replace the normative sections.

ID	Required semantic element	Example validation question	Content-testable?
EOR-01	Event type	Is a stable, documented name or code present?	Yes, with semantic corroboration
EOR-02	Event date and time	Does the event-occurrence value parse to a real date and time?	Yes, with semantic corroboration
EOR-03	Timezone relationship	Is UTC, a fixed offset, or a local offset represented?	Usually
EOR-04	Event location	Is the relevant system, component, service, tenant, facility, or equivalent identifiable?	Usually
EOR-05	Event source	Is the initiating source or producing component identifiable?	Usually
EOR-06	Event outcome	For events with outcomes, is the result represented by a documented value?	Usually
EOR-07	Associated identity	When applicable, are the relevant user, process, service, device, or object identities represented?	Usually
EOR-08	Deterministic structure	Can records and fields be extracted consistently?	Yes
EOR-09	Valid values	Do extracted values satisfy declared types and documented domains?	Yes
EOR-10	Sensitive-data exclusion	Are obvious credentials or secrets absent?	Partially; absence cannot be guaranteed by sampling

Interpretation notes

1. A field may be inherited from a trusted envelope rather than repeated in every physical line, but the association must survive export and analysis.
2. Not every element applies to every event. For example, a scheduler health event may have no human identity or success/failure outcome.
3. A custom event code is acceptable when its definition is stable and available. Numeric position alone is not proof of meaning.
4. Valid syntax and correct semantics are separate findings.
5. “Not observed” shall not be converted into “not supported” without an expectation that the reviewed dataset contained the relevant event.

Appendix B. Control-to-evidence matrix

Topic	Principal source	Record-content evidence	Other evidence required
Event selection	NIST AU-2; 800-171 03.03.01	Observed types only	Approved event inventory and configuration
Record content	NIST AU-3; 800-171 03.03.02	Strong	Field semantics and applicability documentation
Storage capacity	NIST AU-4; CIS 8.3	None	Capacity settings, forecasts, and alerts
Failure response	NIST AU-5; 800-171 03.03.04	Failure events may support	Alert and response configuration, tests, tickets
Review and analysis	NIST AU-6; CIS 8.11	None	Review records, cases, schedules, and reports
Reduction and reporting	NIST AU-7	Searchable fields may support	Platform capability and preservation tests
Time stamps	NIST AU-8; CIS 8.4	Format and offset	Time source configuration and drift evidence
Protection	NIST AU-9	None	Access, encryption, integrity, and deletion controls
Retention	NIST AU-11; CIS 8.10	Dataset span only	Retention policy, configuration, archive, disposal
Generation	NIST AU-12; CIS 8.2	Observed generation	Enabled sources, event tests, coverage inventory

Appendix C. Public source register

The requirements in this example are paraphrased and adapted for the fictional YMMV environment. Readers should consult the authoritative source and its applicability rules before using any requirement in a real organization.

[SRC-NIST-53] NIST SP 800-53 Revision 5, Release 5.2.0

Security and Privacy Controls for Information Systems and Organizations, in particular AU-2 Event Logging, AU-3 Content of Audit Records, AU-4 Audit Log Storage Capacity, AU-5 Response to Audit Logging Process Failures, AU-6 Audit Record Review, Analysis, and Reporting, AU-7 Audit Record Reduction and Report Generation, AU-8 Time Stamps, AU-9 Protection of Audit Information, AU-11 Audit Record Retention, and AU-12 Audit Record Generation.

https://csrc.nist.gov/pubs/sp/800/53/r5/upd1/final

[SRC-NIST-171] NIST SP 800-171 Revision 3

Protecting Controlled Unclassified Information in Nonfederal Systems and Organizations, section 3.3 Audit and Accountability, especially 03.03.01 through 03.03.08.

https://csrc.nist.gov/pubs/sp/800/171/r3/final

[SRC-NIST-92] NIST SP 800-92 and SP 800-92 Revision 1 Initial Public Draft

Guide to Computer Security Log Management provides the established enterprise log-management lifecycle. **Cybersecurity Log Management Planning Guide**, Revision 1 Initial Public Draft, reframes the subject as an organization-wide improvement playbook. Revision 1 was still a draft when this example was issued.

https://csrc.nist.gov/pubs/sp/800/92/final https://csrc.nist.gov/pubs/sp/800/92/r1/ipd

[SRC-CIS-8] CIS Critical Security Controls v8, Control 8

Audit Log Management, Safeguards 8.1 through 8.12, including collection, storage, time synchronization, detailed audit logs, centralization, 90-day minimum retention, weekly review, and service-provider logs.

https://www.cisecurity.org/controls/cis-controls-navigator/v8

[SRC-CIS-BENCH] CIS Benchmarks overview

CIS Benchmarks are community-developed secure-configuration recommendations for specific technology families. Their detailed applicability and version must be evaluated for the actual platform.

https://www.cisecurity.org/cis-benchmarks-overview_new

[SRC-CIS-OL6] CIS Oracle Linux 6 Benchmark v1.0.0

Section 4.1.2, **Ensure auditd service is enabled**, is cited only as a public, platform-specific example showing that audit enablement is a configuration requirement rather than something provable from event content alone. It is not presented as a current baseline for other platforms.

https://www.cisecurity.org/-/jssmedia/Project/cisecurity/cisecurity/data/media/files/uploads/2017/04/CIS_Oracle_Linux_6_Benchmark_v100.pdf

[SRC-ISO-8601] ISO 8601-1:2019

Date and time - Representations for information interchange - Part 1: Basic rules specifies machine-readable representations for Gregorian calendar dates, 24-hour times, UTC, and time shifts from UTC.

https://www.iso.org/standard/70907.html

Appendix D. Educational notice and disclaimer

YMMV Industrial is fictitious. This example is not legal advice, regulatory guidance, an official interpretation of any cited publication, or a substitute for qualified security, privacy, records-management, safety, and legal review. References to NIST, ISO, and CIS do not imply endorsement, certification, or affiliation. Third-party names and standards remain the property of their respective owners.

Copyright 2026 EventMill Project. Educational purposes only. This is not a real corporate standard. It is an example artifact intended for software evaluation, demonstrations, testing, and training.